

Weekly IT Security Brief (Official-source-first) | 2026-09-13

06:00

Formatted for readability · Auto-generated

Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-84869(2026-09-14), CVE-2026-42016(2026-09-25), CVE-2026-42018(2026-09-25). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Protecting organizations from AI-assisted executive impersonation and invoice fraud. Microsoft examines an AI-assisted business email compromise campaign that used executive impersonation and fake invoices to target finance teams with ACH pay...
- Threat trend #2: Detect and disrupt AI-themed attacks with Microsoft Defender. See how Microsoft Defender detects and disrupts AI-themed phishing, malware, and multi-stage attacks across the attack chain. Recommendation: prioritize vulnerable-version inventor...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-84869

CVE Title	CVE-2026-84869 ConnectWise / ScreenConnect Unknown Type
CVE Description	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to file transfer and execution through an active remote sessions without authorization or host confirmation.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	ConnectWise / ScreenConnect
Risk Score	Unverified (Unverified)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-14
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-84869

CVE-2026-42016

CVE Title	CVE-2026-42016 JFrog / Artifactory Privilege Escalation
CVE Description	JFrog Artifactory contains an incorrect authorization vulnerability that allows leads to privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	JFrog / Artifactory
Risk Score	Unverified (Unverified)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-25
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-42016

CVE-2026-42018

CVE Title	CVE-2026-42018 jfrog/artifactory Unknown Type
CVE Description	JFrog Artifactory could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	jfrog/artifactory
Risk Score	7.5 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-25
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-42018

CVE-2026-85706

CVE Title	CVE-2026-85706 待核實 Unknown Type
CVE Description	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	待核實
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-14
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-85706

CVE-2026-86060

CVE Title	CVE-2026-86060 mikrotik/routeros Privilege Escalation
CVE Description	RouterOS contains an argument-handling flaw in the SSH login
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	mikrotik/routeros
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-13
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-86060

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-86148

CVE Title CVE-2026-86148 | 待核實 | Unknown Type

CVE Description A security flaw has been discovered in Tenda CP3 27.5.57.101. This vulnerability affects the function SystemAsh of the file Apis/system.c of the component Kylin. The manipulation of the argument AlarmVoiceURL results in os command injection. It is possible to launch the attack remotely.

Affected Products 待核實

Risk Score 9.1 (CRITICAL)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-86148>

CVE-2026-86149

CVE Title CVE-2026-86149 | 待核實 | Unknown Type

CVE Description A weakness has been identified in Tenda CP3 27.5.57.101. This issue affects some unknown processing of the file Net/NetCheckPing.cpp. This manipulation of the argument interface_name/host causes os command injection. The attack can be initiated remotely.

Affected Products 待核實

Risk Score 9.1 (CRITICAL)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-86149>

CVE-2026-76160

CVE Title	CVE-2026-76160 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-76160

CVE-2026-76161

CVE Title	CVE-2026-76161 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-76161



Report B: Threat Intelligence News (last 7 days)

Headline: Protecting organizations from AI-assisted executive impersonation and invoice fraud

Source	Microsoft Security Blog
Published	Thu, 10 Sep 2026 17:23:05 +0000
Key Takeaway	Microsoft examines an AI-assisted business email compromise campaign that used executive impersonation and fake invoices to target finance teams with ACH payment fraud. The post Protecting organizations from AI-assisted executive impersonation and invoice fraud appeared first on Microsoft Security B Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/10/protecting-organizations-ai-assisted-executive-impersonation-invoice-fraud/

Headline: Detect and disrupt AI-themed attacks with Microsoft Defender

Source	Microsoft Security Blog
Published	Thu, 10 Sep 2026 16:00:00 +0000
Key Takeaway	See how Microsoft Defender detects and disrupts AI-themed phishing, malware, and multi-stage attacks across the attack chain. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/10/detect-and-disrupt-ai-themed-attacks-with-microsoft-defender/

Headline: CISA Releases Updated Insider Threat Guide With New Insights to Mitigate Physical and Cyber Threats

Source	CISA News
Published	Wed, 09 Sep 26 12:00:00 +0000
Key Takeaway	CISA Releases Updated Insider Threat Guide With New Insights to Mitigate Physical and Cyber Threats Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-releases-updated-insider-threat-guide-new-insights-mitigate-physical-and-cyber-threats

Headline: CISA, NSA and FBI Warn of China-Based AI Companies Targeting US AI Models with Industrial-Scale Knowledge Distillation Campaigns to Shortcu...

Source	CISA News
Published	Tue, 08 Sep 26 12:00:00 +0000
Key Takeaway	CISA, NSA and FBI Warn of China-Based AI Companies Targeting US AI Models with Industrial-Scale Knowledge Distillation Campaigns to Shortcut AI Development Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	industrial/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-nsa-and-fbi-warn-china-based-ai-companies-targeting-us-ai-models-industrial-scale-knowledge

Headline: We've got one word for it, and it's usually the wrong one

Source Cisco Talos Blog

Published Thu, 10 Sep 2026 18:00:15 GMT

Key Takeaway In this week's Threat Source newsletter, Joe explores why the word "burnout" often fails to capture the true toll of working in the cybersecurity industry and why we need better language to address it. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/weve-got-one-word-for-it-and-its-usually-the-wrong-one/>

Headline: Active exploitation of Cisco Secure Firewall Management Center vulnerabilities

Source Cisco Talos Blog

Published Wed, 09 Sep 2026 16:08:59 GMT

Key Takeaway Cisco Talos is actively tracking the exploitation of two vulnerabilities in Cisco's Secure Firewall Management Center (FMC) Software.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/fmc-ongoing-exploitation/>

Headline: CISA Adds 5 Actively Exploited Artifactory, ScreenConnect, and RouterOS Flaws to KEV

Source	The Hacker News
Published	Sat, 12 Sep 2026 21:24:45 +0530
Key Takeaway	Cybersecurity and Infrastructure Security Agency (CISA) has added five security flaws impacting JFrog Artifactory, ConnectWise ScreenConnect, and MikroTik RouterOS to its Known Exploited Vulnerabilities (KEV) catalog, following reports of active exploitation in the wild. Details of the vulnerability Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-42016
Link	https://thehackernews.com/2026/09/cisa-adds-5-actively-exploited.html

Headline: When the Whole Company Adopts AI: What It Does to Your SOC

Source	The Hacker News
Published	Sat, 12 Sep 2026 15:54:44 +0530
Key Takeaway	Over the past year, we watched a new class of alert appear in enterprise security operations centers and grow faster than anything else in the stream: alerts that were triggered by AI tools and agents. Not attacks against AI, but the ordinary, everyday footprint of an organization using it, from dev Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/09/when-whole-company-adopts-ai-what-it.html

Headline: BlueMoon Exploit Kit Chains Recent Chrome, Windows Zero-Days

Source	SecurityWeek
Published	Sat, 12 Sep 2026 11:10:00 +0000
Key Takeaway	The post BlueMoon Exploit Kit Chains Recent Chrome, Windows Zero-Days appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/bluemoon-exploit-kit-chains-recent-chrome-windows-zero-days/

Headline: Users in Houthi-Held Yemen Tried to Develop Advanced Weapons With AI, Anthropic Says

Source	SecurityWeek
Published	Sat, 12 Sep 2026 01:50:53 +0000
Key Takeaway	Anthropic said the users did not succeed in “fielding an operational device” but did carry out a failed test of a guided rocket. The post Users in Houthi-Held Yemen Tried to Develop Advanced Weapons With AI, Anthropic Says appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/users-in-houthi-held-yemen-tried-to-develop-advanced-weapons-with-ai-anthropic-says/

Headline: Dutch NCSC: Critical Check Point VPN flaws exploitation is imminent

Source BleepingComputer

Published Sat, 12 Sep 2026 10:14:32 -0400

Key Takeaway The Dutch Nationaal Cyber Security Centrum (NCSC) is warning of imminent exploitation of two critical flaws in Check Point VPN tracked as CVE-2026-85102 and CVE-2026-85103. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs CVE-2026-85102, CVE-2026-85103

Link <https://www.bleepingcomputer.com/news/security/dutch-ncsc-critical-check-point-vpn-flaws-exploitation-is-imminent/>

Headline: Hackers abused Claude to extract secrets from 1.8M Android apps

Source BleepingComputer

Published Fri, 11 Sep 2026 16:19:09 -0400

Key Takeaway Anthropic says multiple threat groups, including the financially motivated and state-sponsored espionage groups linked to Russia and China, tried to abuse its Claude AI model for malicious purposes. [...]
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target financial/待核實

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/hackers-abused-claude-to-extract-secrets-from-18m-android-apps/>

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)